

STANDARD OPERATING PROCEDURE (SOP)

KEAMANAN JARINGAN – INCIDENT RESPONSE & MITIGATION (ENTERPRISE / RAG-OPTIMIZED v2)

BAB 1: [PROT-DDoS] - MITIGASI DISTRIBUTED DENIAL OF SERVICE

Gejala Utama:

- Lonjakan trafik TCP SYN pada port 80/443 dengan rasio SYN/ACK tidak seimbang.
- UDP flood pada port 53 (DNS), 123 (NTP), 1900 (SSDP).
- Bandwidth utilization interface WAN >90% (SNMP ifInOctets/ifOutOctets).
- NetFlow menunjukkan peningkatan source IP unik (entropy tinggi).

Diferensiasi Diagnosa (DDoS vs Flash Crowd):

- Jalankan pada server:
 - `netstat -n | grep :80 | wc -l` → total koneksi aktif
 - `netstat -ant | grep SYN_RECV` → indikasi SYN flood
- Analisis karakteristik:
 - **Flash Crowd:**
 - IP dominan berasal dari ASN valid (ISP publik)
 - HTTP User-Agent variatif & valid
 - Session completion tinggi (ESTABLISHED)
 - **DDoS:**
 - Banyak IP spoofed / geo anomali
 - User-Agent kosong / identik
 - Banyak koneksi stuck di SYN_RECV

Sumber Log Validasi:

- NetFlow/IPFIX (router core/perimeter)
- Firewall session table
- Web server access log (status code distribution)
- IDS alert (SYN flood, amplification attack)

Langkah Teknis:

1. Validasi spike trafik via NetFlow collector (top talker, protocol breakdown).
2. Aktifkan SYN cookies:
 - `sysctl -w net.ipv4.tcp_syncookies=1`

3. Terapkan rate limiting:
 - iptables:
 - `-A INPUT -p tcp --syn -m limit --limit 30/s -j ACCEPT`
4. Deploy ACL anti-spoofing:
 - Drop RFC1918 inbound dari WAN.
5. Implementasi **RTBH (Remotely Triggered Blackhole Routing)**:
 - `ip route <target_ip> 255.255.255.255 null0`
6. Integrasi proteksi berbasis CDN/WAF:
 - API call (Cloudflare example):
 - `POST /client/v4/zones/{zone_id}/settings/security_level`
7. Automation Playbook:
 - Trigger dari SIEM (Splunk/ELK):
 - Condition: traffic > threshold + SYN_RECV spike
 - Action:
 - Push firewall rule via API
 - Enable rate limit policy otomatis
8. Eskalasi: **Jira Ticket: NET-SEC-DDoS-L3**
 - Lampiran wajib: NetFlow PCAP summary + grafik bandwidth

BAB 2: [PROT-SQLI] - PENANGANAN SQL INJECTION PADA DATABASE

Gejala Utama:

- Payload HTTP mengandung ' OR 1=1--, ' UNION SELECT
- HTTP 500 spike pada endpoint API
- WAF trigger rule SQLi (ModSecurity CRS ID)
- Query DB tidak normal (slow query / full table scan)

Sumber Log Validasi:

- WAF audit log (rule ID, matched data)
- Web server access log
- Database query log (general_log, slow_query_log)
- Application stack trace

Langkah Teknis:

1. Identifikasi attacker IP:
 - `grep -i "union select" access.log | awk '{print $1}'`
2. Blokir IP:
 - WAF rule deny (HTTP 403)
 - NGINX:
 - `deny <ip>;`
3. Automation Playbook:
 - SIEM → WAF API:

- Trigger rule block IP otomatis jika >5 SQLi attempt/menit.
- 4. Validasi endpoint:
 - Reproduce exploit via curl:
 - `curl -X GET "https://target/api?id=1' OR '1'='1"`
- 5. Hardening aplikasi:
 - Gunakan Prepared Statement (JDBC, PDO, ORM)
 - Input validation whitelist (regex strict)
- 6. Disable verbose error:
 - `display_errors=Off`
- 7. Database security:
 - Least privilege user:
 - `GRANT SELECT, INSERT (tanpa DROP/ALTER)`
- 8. Eskalasi: **Jira Ticket: APP-SEC-SQLI-L3**
 - Lampiran: payload sample + endpoint rentan + log WAF

BAB 3: [PROT-MALW] - ISOLASI LATERAL MOVEMENT MALWARE

Gejala Utama:

- Trafik lateral pada port:
 - 445 (SMB), 3389 (RDP), 135 (RPC)
- Event ID 4625 (failed login), brute-force RDP
- Hash file mencurigakan (EDR detection)
- Spike east-west traffic antar VLAN

Sumber Log Validasi:

- EDR/XDR telemetry (hash, process tree)
- Windows Event Log (Security, Sysmon)
- Firewall internal log
- NetFlow core switch

Langkah Teknis:

1. Identifikasi host:
 - Query hash di EDR:
 - `sha256:<hash>`
2. **Isolation Without Disconnection (MANDATORY):**
 - Isolasi via VLAN quarantine:
 - `interface vlan <id> → assign quarantine VLAN`
 - **DILARANG cabut kabel fisik / shutdown NIC**
 - Reason: malware anti-forensic akan self-delete saat link down.
3. Blokir lateral movement:
 - ACL:
 - `deny tcp any any eq 445`

- `deny tcp any any eq 3389`
 - 4. **DILARANG power off endpoint/server**
 - Preserve volatile memory (RAM forensic).
 - 5. Memory acquisition:
 - Tools:
 - `winpmem, DumpIt`
 - 6. Disk imaging:
 - `FTK Imager` (forensic image E01)
 - 7. Kill process:
 - Berdasarkan EDR (PID + parent process chain).
 - 8. Reset credential:
 - Force password reset via Active Directory.
 - 9. Automation Playbook:
 - EDR auto-isolate endpoint:
 - Trigger: malicious hash detected
 - Action: isolate host (network containment mode)
 - 10. Eskalasi: **Jira Ticket: IR-DFIR-MALW-L3**
- Lampiran: hash IOC + memory dump reference + timeline event

BAB 4: [PROT-RECO] - PROTOKOL PEMULIHAN SISTEM (POST-INCIDENT)

Tujuan:

Mengembalikan sistem dengan integritas terverifikasi dan tanpa persistence threat.

Sumber Validasi:

- EDR full scan report
- File Integrity Monitoring (FIM)
- Backup checksum log
- SIEM anomaly dashboard

Langkah Teknis:

1. Full scan EDR:
 - Signature + behavioral analysis
2. Verifikasi integritas:
 - `sha256sum -c baseline_hash.txt`
3. Restore backup:
 - Validasi:
 - Pre-incident timestamp
 - Checksum match
4. Patch vulnerability:
 - Apply CVE patch:
 - `apt update && apt upgrade`

5. Automation Playbook:
 - CI/CD pipeline enforce:
 - Security patch sebelum deployment
6. Reintegrasi jaringan:
 - Flow:
 - Quarantine VLAN → Staging VLAN → Production VLAN
7. Monitoring 24 jam:
 - SIEM rule:
 - Detect outbound anomaly
 - Detect IOC reuse
8. Re-enable port/service:
 - 445/3389 hanya via:
 - VPN + MFA + IP allowlist
9. Closure:
 - Jira Ticket: **POST-INCIDENT-RECO-L3**
 - Wajib:
 - Root Cause Analysis (RCA)
 - Indicator of Compromise (IOC)
 - Lessons Learned

ENHANCEMENT SUMMARY (RAG SIGNAL BOOST)

- **Diagnostik presisi tinggi:**
 - DDoS vs Flash Crowd berbasis state koneksi & entropy trafik.
- **Forensik kuat (Chain of Custody):**
 - Isolation tanpa memutus koneksi fisik.
 - Preservasi RAM untuk volatile artifact.
- **Automasi & Skalabilitas:**
 - Integrasi SIEM → WAF/Firewall API.
 - EDR auto-containment.
- **Semantic Separation kuat:**
 - Tidak ada overlap keyword antar [PROT-*].
 - Setiap bab punya signature teknis unik (port, log, tool, command).

ADDENDUM: [PROT-MALW-LNX-LIVE] – LIVE FORENSICS LINUX (ORDER OF VOLATILITY)

Konteks:

Addendum ini memperluas [PROT-MALW] dengan fokus pada **live forensics berbasis Linux** (Ubuntu/Debian/Mint/RHEL). Seluruh akuisisi data mengikuti prinsip **Order of Volatility (OoV)**: RAM → proses → jaringan → filesystem → disk.

Prinsip Operasional:

- Semua perintah bersifat **read-only** (tidak mengubah state sistem).
- Gunakan shell dengan minimal footprint (hindari instalasi tools baru).
- Output diarahkan ke media eksternal jika memungkinkan (/mnt/forensic).
- Gunakan timestamp:
 - `date -u +"%Y-%m-%dT%H:%M:%SZ"`

URUTAN AKUISISI (ORDER OF VOLATILITY)

1. **Memory Artifacts (Indirect via /proc)**
2. **Running Processes**
3. **Active Network Connections**
4. **Persistence Mechanisms**
5. **Filesystem Artifacts**

TABEL PERINTAH LIVE FORENSICS (READ-ONLY CLI)

Kategori	Perintah CLI	Penjelasan Teknis
Analisis Proses	<code>`ps aux --sort=-%cpu`</code>	<code>head -n 15`</code>
	<code>`ps aux --sort=-%mem`</code>	<code>head -n 15`</code>
	<code>ps -ef --forest</code>	Visualisasi parent-child process tree untuk mendeteksi proses anomali (misal: shell spawn dari web server).
	<code>cat /proc/<PID>/cmdline</code>	Melihat command-line asli proses (menghindari masking nama proses).
	<code>ls -l /proc/<PID>/exe</code>	Menunjukkan path binary sebenarnya (deteksi binary di /tmp atau deleted file). Output contoh: <code>/proc/1337/exe -> /tmp/.malware (deleted)</code>

Kategori	Perintah CLI	Penjelasan Teknis
Analisis Jaringan	<code>ss -tulnp</code>	Menampilkan semua listening port + PID mapping. Fokus pada port tidak dikenal. Contoh: <code>tcp LISTEN 0 128 0.0.0.0:4444 users: (("nc",pid=1337))</code>
	<code>ss -antp</code>	Koneksi TCP aktif (ESTABLISHED). Identifikasi koneksi outbound ke IP asing (C2).
	<code>cat /proc/net/tcp</code>	Low-level socket info (hex format), berguna jika tools dimanipulasi.
	<code>lsof -i</code>	Mapping file descriptor ke koneksi jaringan. Deteksi binary mencurigakan membuka koneksi.
	<code>ip addr show</code>	Validasi interface & IP tambahan (possible rogue interface/tunnel).

Kategori	Perintah CLI	Penjelasan Teknis
Analisis Persistence	<code>crontab -l</code>	Cron job user saat ini. Cari job mencurigakan (reverse shell, wget).
	<code>ls -al /etc/cron*</code>	Enumerasi cron system-wide. Output contoh: file dengan nama tidak biasa.
	<code>systemctl list-units --type=service --state=running</code>	Service aktif. Identifikasi service tidak dikenal.
	<code>systemctl list-unit-files --type=service</code>	Service yang di-enable saat boot (persistence via systemd).
	<code>cat /etc/passwd</code>	Deteksi user baru (UID tidak biasa, shell <code>/bin/bash</code> mencurigakan).
	<code>grep -i "exec" ~/.bashrc ~/.profile</code>	Deteksi backdoor via shell initialization.

Kategori	Perintah CLI	Penjelasan Teknis
Analisis File	<code>ls -alh /tmp /dev/shm</code>	Direktori volatile untuk malware fileless/staging. Cari file tersembunyi (. prefix).
	<code>find /tmp -type f -mmin -60</code>	File yang dibuat/diubah dalam 60 menit terakhir.
	<code>find /dev/shm -type f</code>	Memory-backed filesystem (sering digunakan malware).
	<code>stat <file></code>	Metadata file (timestamp: atime, mtime, ctime).
	<code>file <file></code>	Identifikasi tipe file sebenarnya (binary vs script).
	<code>`strings`</code>	<code>head`</code>

INDIKATOR KOMPROMI (LINUX-SPECIFIC IOC)

- Binary berjalan dari:
 - /tmp, /dev/shm, /var/tmp
- Proses dengan status:
 - (deleted) namun masih running (/proc/<PID>/exe)
- Koneksi outbound ke:
 - IP publik non-whitelisted (port 4444, 1337, 8081, dll)
- Cron job:
 - Mengandung curl, wget, bash -i >& /dev/tcp/
- Service systemd:
 - Nama menyerupai sistem (systemd-update.service palsu)

PROSEDUR PENGUMPULAN OUTPUT (FORENSICALLY SOUND)

- Redirect output ke file:
- `ps aux > /mnt/forensic/ps_aux_$(date -u +%s).log`
- `ss -antp > /mnt/forensic/ss_antp_$(date -u +%s).log`
- Gunakan mount read-only jika memungkinkan:
- `mount -o ro /dev/sdb1 /mnt/forensic`
- Hash hasil akuisisi:
- `sha256sum /mnt/forensic/* > /mnt/forensic/hashes.txt`

CATATAN KRITIS DFIR

- **JANGAN menjalankan binary yang ditemukan** (hindari execution).
- **JANGAN menghapus file atau kill process** sebelum akuisisi selesai.
- **Prioritaskan artefak volatile** sebelum reboot/shutdown.
- Jika diperlukan memory dump penuh:
 - Gunakan tools seperti **LiME** (hanya jika approved, karena bukan default binary).

INTEGRASI DENGAN [PROT-MALW]

- Step ini dilakukan **setelah isolasi VLAN** dan sebelum eradikasi.
- Output digunakan oleh:
 - DFIR Team untuk timeline reconstruction
 - Threat Intelligence untuk IOC enrichment
- Referensi eskalasi:
 - **Jira Ticket: IR-DFIR-MALW-LNX-LIVE**

RAG OPTIMIZATION NOTES

- Identifier unik: [PROT-MALW-LNX-LIVE]
- Keyword spesifik:
 - /proc, ss -antp, systemctl, /dev/shm
- Tidak overlap dengan Windows-based malware analysis
- Struktur tabel memudahkan chunk retrieval presisi tinggi